

Dan Boneh 《Cryptography I》第四课：使用分组密码

依据课程原版讲义 04-using-block-annotated.pdf (54 页) 整理。

本课主线：PRF/PRP 复习 → 单次密钥安全 → ECB 的问题 → 多次密钥与 CPA 安全 → 随机化/nonce 加密 → CBC → CTR → 模式比较与局限。

0. 本课要解决的问题

上一课介绍了 AES、3DES 等分组密码。分组密码只提供一个固定长度分组上的伪随机置换：

$$E : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{X}$$

它并没有直接告诉我们怎样加密任意长度的消息。

本课讨论如何用安全 PRP/PRF 构造真正的加密方案，重点回答：

1. 为什么不能把每个明文分组直接交给 AES？
2. 单次密钥安全与多次密钥 CPA 安全有什么区别？
3. 为什么重复加密同一明文必须产生不同密文？
4. 随机 IV、nonce 和 counter 分别有什么要求？
5. CBC 如何加密和解密？为什么 IV 可预测会破坏安全？
6. CTR 为什么可以并行、无需填充，并且安全界优于 CBC？
7. 为什么 CBC 和 CTR 都不能单独保证完整性？

1. PRF 与 PRP 复习

1.1 伪随机函数 PRF

PRF 定义为：

$$F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{Y}$$

固定密钥 k 后：

$$F(k, \cdot) : \mathcal{X} \rightarrow \mathcal{Y}$$

是一个确定性函数。

安全 PRF 要求随机密钥函数 $F(k, \cdot)$ 与真正随机函数

$$f \leftarrow \text{Funs}[\mathcal{X}, \mathcal{Y}]$$

对高效攻击者不可区分。

1.2 PRF 安全游戏

挑战者随机选择一个固定比特 b ：

- $b = 0$: oracle 为 $F(k, \cdot)$ ，其中 $k \leftarrow \mathcal{K}$ ；

- $b = 1$: oracle 为真正随机函数 f 。

攻击者可以自适应查询：

$$x_1, x_2, \dots, x_q$$

并获得相应输出，最后猜测 b' 。

定义：

$$\text{Adv}_{\text{PRF}}[A, F] = |\Pr[\text{EXP}(0) = 1] - \Pr[\text{EXP}(1) = 1]|$$

若所有高效攻击者的优势均可忽略，则 F 是安全 PRF。

1.3 伪随机置换 PRP

PRP 定义为：

$$E : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{X}$$

对每个固定密钥 k ， $E(k, \cdot)$ 都是可高效求逆的置换。

安全 PRP 要求：

$$E(k, \cdot)$$

与均匀随机置换

$$\pi \leftarrow \text{Perms}[\mathcal{X}]$$

对高效攻击者不可区分。

AES 和 3DES 在课程中视为安全 PRP 候选。

2. PRP 不一定是安全 PRF

2.1 一个一位 PRP

令：

$$\mathcal{K} = \mathcal{X} = \{0, 1\}$$

定义：

$$E(k, x) = x \oplus k$$

当 $k = 0$ 时，它是恒等置换；当 $k = 1$ 时，它交换 0 和 1。

$\{0, 1\}$ 上一共只有这两个置换，所以随机选择 k 与随机选择置换完全相同。它是完美的 PRP。

2.2 为什么它不是安全 PRF

$\{0, 1\}$ 到自身共有四个函数，其中两个不是置换：

$$f(0)=0, f(1)=0$$

$$f(0)=1, f(1)=1$$

攻击者查询 0 和 1:

- 若 $f(0) = f(1)$, 判断是真正随机函数;
- 若 $f(0) \neq f(1)$, 判断是 PRP。

对于 PRP, 碰撞概率为 0; 对于随机函数, 碰撞概率为 $1/2$ 。因此优势为:

$$\frac{1}{2}$$

根本原因是: 置换禁止输出碰撞, 随机函数允许输出碰撞。

3. PRF Switching Lemma

当定义域足够大、攻击者查询数不太多时, 攻击者很难观察到随机函数的输出碰撞, 因而随机置换与随机函数看起来相似。

设 E 是定义在 $(\mathcal{K}, \mathcal{X})$ 上的 PRP。对任意最多查询 q 次的攻击者 A :

$$|\text{Adv}_{\text{PRF}}[A, E] - \text{Adv}_{\text{PRP}}[A, E]| < \frac{q^2}{2|\mathcal{X}|}$$

若:

$$q^2 \ll |\mathcal{X}|$$

则差异可忽略, 安全 PRP 也可以当作安全 PRF 使用。

3.1 生日界直觉

真正随机函数在 q 次查询中发生输出碰撞的概率约为:

$$\frac{q(q-1)}{2|\mathcal{X}|} \approx \frac{q^2}{2|\mathcal{X}|}$$

而随机置换绝不碰撞。只有观察到碰撞, 攻击者才有直接证据说明自己面对随机函数。

当 q 接近 $\sqrt{|\mathcal{X}|}$ 时, 碰撞不再罕见, 这就是生日界。

对于 AES:

$$|\mathcal{X}| = 2^{128}$$

生日界大约出现在 2^{64} 个分组附近。

4. 从分组密码到消息加密

4.1 两种使用场景

课程把问题分为两种模型。

单次密钥 (one-time key):

- 一个密钥只加密一条消息;
- 攻击者只看到一个挑战密文;
- 例如为每封邮件生成独立新密钥。

多次密钥 (many-time key):

- 同一密钥加密许多消息;
- 攻击者能够观察或请求许多密文;
- 例如文件系统使用同一 AES 密钥加密多个文件, IPsec 使用同一密钥加密多个数据包。

多次密钥模型更接近现实, 也需要更强的安全定义。

5. ECB: 错误的直接使用方式

5.1 ECB 的做法

把消息分成分组:

$$m = m[0] \parallel m[1] \parallel \dots \parallel m[L]$$

分别加密:

$$c[i] = E(k, m[i])$$

这称为电子密码本模式 ECB。

5.2 ECB 泄露相等关系

因为 $E(k, \cdot)$ 是确定性函数:

$$m[i] = m[j] \implies c[i] = c[j]$$

所以密文会暴露:

- 哪些明文分组相同;
- 重复数据的位置;
- 图像和文件中的结构模式。

这就是经典 ECB 加密图片仍能看出轮廓的原因。

5.3 ECB 不是语义安全的

攻击者选择两个两分组消息:

```
m0 = "Hello World"    (两个分组不同)
m1 = "Hello Hello"    (两个分组相同)
```

收到密文 $(c[0], c[1])$ 后：

- 若 $c[0] = c[1]$ ，猜测加密的是重复分组消息；
- 否则猜测另一条消息。

攻击者总能正确判断，优势为 1。

因此，即使每条消息都使用新密钥，只要一条消息含多个分组，ECB 仍不具备语义安全性。

结论：ECB 不应用于一般数据加密。

6. 单次密钥语义安全

攻击者选择两个等长消息：

$$m_0, m_1$$

挑战者生成随机密钥 k ，并根据秘密比特 b 返回：

$$c \leftarrow E(k, m_b)$$

攻击者输出猜测。

课程使用的优势写法为：

$$\text{Adv}_{\text{SS}}[A, E] = |\Pr[\text{EXP}(0) = 1] - \Pr[\text{EXP}(1) = 1]|$$

若任意高效攻击者的优势可忽略，则方案在单次密钥模型下语义安全。

这里要求 $|m_0| = |m_1|$ ，因为普通加密方案通常不会隐藏消息长度。

7. 确定性计数器模式：仅适用于单次密钥

7.1 构造

设：

$$F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{X}$$

是安全 PRF。对于分组消息：

$$m[0], m[1], \dots, m[L]$$

生成密钥流：

$$F(k, 0), F(k, 1), \dots, F(k, L)$$

并计算：

$$c[i] = m[i] \oplus F(k, i)$$

即：

$$E_{\text{DETCR}}(k, m) = m \oplus (F(k, 0) \parallel \dots \parallel F(k, L))$$

7.2 为什么单次使用时安全

若 F 是安全 PRF，则：

$$F(k, 0), \dots, F(k, L)$$

与独立均匀随机分组计算不可区分。将其替换为真随机串后，整个方案就是 OTP。

因此，对于固定消息长度，安全 PRF 可以导出单次密钥语义安全方案。

课程给出的归约关系为：

$$\text{Adv}_{\text{SS}}[A, E_{\text{DETCR}}] = 2 \text{Adv}_{\text{PRF}}[B, F]$$

7.3 为什么不能多次使用

若同一密钥再次从计数器 0 开始，则会重复同一密钥流：

$$c_1[i] = m_1[i] \oplus F(k, i)$$

$$c_2[i] = m_2[i] \oplus F(k, i)$$

于是：

$$c_1[i] \oplus c_2[i] = m_1[i] \oplus m_2[i]$$

形成 two-time pad 攻击。

所以确定性 CTR 只在密钥确实只使用一次时安全。

8. 多次密钥与 CPA 安全

8.1 为什么攻击者可以选择明文

现实中，攻击者经常可以影响被加密的内容，例如：

- 向服务器发送自己构造的数据；
- 诱导浏览器发出包含已知字段的请求；
- 在文件或协议报文中控制部分内容；
- 调用公开加密 API。

因此采用保守模型：攻击者能够请求任意自选明文的加密结果。这称为选择明文攻击（Chosen-Plaintext Attack, CPA）。

8.2 多次密钥语义安全游戏

挑战者随机选择一个固定比特：

$$b \leftarrow \{0, 1\}$$

并生成一次密钥：

$$k \leftarrow \mathcal{K}$$

攻击者进行 q 轮查询。第 i 轮提交一对等长消息：

$$(m_{i,0}, m_{i,1})$$

挑战者始终返回同一侧消息的加密：

$$c_i \leftarrow E(k, m_{i,b})$$

最后攻击者猜测 b 。

定义：

$$\text{Adv}_{\text{CPA}}[A, E] = |\Pr[\text{EXP}(0) = 1] - \Pr[\text{EXP}(1) = 1]|$$

若对所有高效攻击者该优势可忽略，则 E 在 CPA 下语义安全。

8.3 普通加密查询如何表示

如果攻击者只想获得某条消息 m 的加密，它可以提交：

$$m_{i,0} = m_{i,1} = m$$

无论秘密比特是哪一侧，挑战者都会返回 $E(k, m)$ 。

8.4 为什么秘密比特必须始终相同

所有查询共用同一个 b ，攻击者才是在判断系统一直加密左侧消息还是一直加密右侧消息。

如果每次查询重新随机选择 b ，游戏将不再表达“攻击者能否区分两类加密世界”。

9. 确定性加密不可能达到 CPA 安全

假设同一密钥下：

$$E(k, m)$$

对相同消息始终产生相同密文。

攻击者可以：

1. 提交普通查询 (m_0, m_0) ，得到 $c_0 = E(k, m_0)$ ；
2. 再提交挑战对 (m_0, m_1) ，得到 c ；
3. 若 $c = c_0$ ，判断加密的是 m_0 ；否则判断是 m_1 。

攻击者可以完全正确地区分。

因此，多次使用同一密钥时必须满足：

$E(k, m)$ 的两次执行应产生不同密文

这可以通过随机化加密或唯一 nonce 实现。

10. 方案一：随机化加密

10.1 基本形式

加密算法内部随机选择 r :

$$r \leftarrow \mathcal{R}$$

即使密钥和明文相同, 不同的 r 也会使密文不同。

随机量通常需要随密文发送, 因此密文比明文更长:

$$|c| \approx |m| + |r|$$

10.2 PRF 构造

设:

$$F: \mathcal{K} \times \mathcal{R} \rightarrow \mathcal{M}$$

是安全 PRF。定义:

$$E(k, m): \quad r \leftarrow \mathcal{R}, \quad c = (r, F(k, r) \oplus m)$$

解密:

$$m = F(k, r) \oplus c_{\text{body}}$$

10.3 安全的关键条件

不仅要求 F 安全, 还要求随机数空间 $\mathcal{R}$ 足够大, 使同一密钥下 r 的重复概率可忽略。

若加密 q 次, 随机 r 的碰撞概率约为:

$$\frac{q^2}{2|\mathcal{R}|}$$

一旦 r 重复, 对应 PRF 输出也重复, 从而复用同一密钥流。

因此正确结论是:

当 F 是安全 PRF, 并且 $\mathcal{R}$ 足够大, 使随机 r 几乎不重复时, 该方案才具有 CPA 安全性。

11. 方案二: 基于 nonce 的加密

11.1 nonce 是什么

nonce 是“只使用一次的值”(number used once)。它不一定随机, 也通常不需要保密。

核心要求:

(k, n) 组合不能重复

即同一密钥下, 每条消息使用不同 nonce。

11.2 nonce 的产生方式

计数器 nonce:

$$0, 1, 2, 3, \dots$$

- 不需要随机数发生器；
- 只要状态不回退，就能保证唯一；
- 适合加密端能够持久保存状态的场景。

随机 nonce:

$$n \leftarrow \mathcal{N}$$

- 无需保存连续计数状态；
- 必须有足够大的空间，把碰撞概率降到可忽略。

11.3 nonce 是否需要发送

如果解密方不能从协议状态推导 nonce，就必须把 nonce 和密文一起发送。

nonce 公开并不破坏安全性。其职责是避免重复，而不是隐藏内容。

11.4 nonce-based CPA 安全游戏

攻击者可以选择每次查询的 nonce：

$$n_i$$

并选择等长消息对：

$$(m_{i,0}, m_{i,1})$$

挑战者返回：

$$c_i \leftarrow E(k, m_{i,b}, n_i)$$

唯一限制是：

$$n_1, n_2, \dots, n_q$$

必须互不相同。

定义要求即使 nonce 由攻击者选择，只要不重复，方案仍然安全。这比假设 nonce 随机诚实地产生更稳健。

11.5 基于计数器的 PRF 加密

令计数器初值为 0，每次加密先递增，然后计算：

$$c = (r, F(k, r) \oplus m)$$

只要计数器在同一密钥下绝不重复，且 F 是安全 PRF，就不需要依赖生日概率保证安全。

12. CBC：随机 IV 构造

12.1 加密公式

设消息分为 $L + 1$ 个分组：

$$m[0], m[1], \dots, m[L] \text{ in } \mathcal{X}$$

随机选择：

$$IV \leftarrow \mathcal{X}$$

令：

$$c[-1] = IV$$

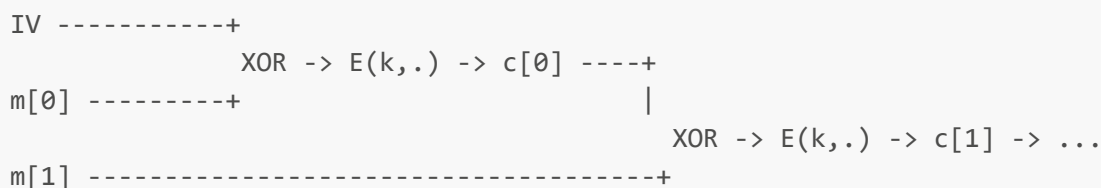
然后依次计算：

$$c[i] = E(k, m[i] \oplus c[i-1])$$

完整密文为：

$$c = IV \parallel c[0] \parallel c[1] \parallel \dots \parallel c[L]$$

12.2 链式结构



每个密文分组都会参与下一个明文分组的加密，因此称为 Cipher Block Chaining。

12.3 解密公式

由：

$$c[i] = E(k, m[i] \oplus c[i-1])$$

先解密得到：

$$D(k, c[i]) = m[i] \oplus c[i-1]$$

再异或前一个密文分组：

$$m[i] = D(k, c[i]) \oplus c[i-1]$$

其中首块使用：

$$m[0] = D(k, c[0]) \oplus IV$$

12.4 CBC 的并行性

加密时必须先得到 $c[i-1]$ 才能计算 $c[i]$ ，因此 CBC 加密不能直接并行。

解密时所有 $D(k, c[i])$ 可以并行计算，因为全部密文分组已经已知；之后分别与前一块异或。

13. CBC 的 CPA 安全界

若 E 是定义在 $(\mathcal{K}, \mathcal{X})$ 上的安全 PRP，对于查询 q 条消息、每条最多 L 个分组的攻击者，课程给出：

$$\text{Adv}_{\text{CPA}}[A, E_{\text{CBC}}] \leq 2 \text{Adv}_{\text{PRP}}[B, E] + \frac{2q^2 L^2}{|\mathcal{X}|}$$

因此需要：

$$q^2 L^2 \ll |\mathcal{X}|$$

13.1 碰撞直觉

CBC 安全证明需要避免不同加密过程中，分组密码的输入值发生碰撞。

总共大约处理 qL 个分组，生日碰撞项约为：

$$\frac{(qL)^2}{|\mathcal{X}|} = \frac{q^2 L^2}{|\mathcal{X}|}$$

这就是安全界中 L^2 的来源。

13.2 AES 与 3DES 示例

若希望碰撞项小于约 2^{-32} ：

对于 AES：

$$|\mathcal{X}| = 2^{128}$$

需要近似满足：

$$qL < 2^{48}$$

即同一密钥处理约 2^{48} 个 AES 分组后应更换密钥。

对于 3DES：

$$|\mathcal{X}| = 2^{64}$$

需要近似满足：

$$qL < 2^{16}$$

这体现了 64 位分组在大量数据场景中的严重限制。

14. CBC 的 IV 要求

14.1 随机 IV 不等于仅仅唯一

在随机 IV CBC 中，IV 必须：

- 均匀随机；
- 在攻击者选择当前明文时不可预测；
- 与密文一起发送即可，不需要保密。

只保证 IV 不重复，但让攻击者提前知道下一 IV，并不足以保证 CBC 的 CPA 安全。

14.2 可预测 IV 攻击

假设攻击者知道下一条消息将使用 IV_1 ，并已见过某个 CBC 首块：

$$c[0] = E(k, m \oplus IV)$$

攻击者可以构造新明文首块：

$$m' = m \oplus IV \oplus IV_1$$

那么新 CBC 输入为：

$$m' \oplus IV_1 = m \oplus IV$$

因此会产生相同首个密文分组。攻击者由相等关系即可区分挑战消息。

14.3 TLS 1.0 的问题

PPT 提到 SSL/TLS 1.0：第 i 条记录的 IV 使用第 $i - 1$ 条记录的最后一个密文分组。

该值在选择下一条记录内容前已经可见，因此 IV 可预测，产生了可被利用的 CPA 弱点。这类问题后来形成了针对 TLS 1.0 CBC 的实际攻击背景。

14.4 API 责任

许多底层 CBC API 要求调用者自己提供 IV。若调用者：

- 使用全零 IV；
- 重复使用固定 IV；
- 使用简单可预测计数器作为随机 CBC IV；

就会破坏安全性。

因此应优先使用能正确管理 nonce/IV 的高层认证加密 API。

15. 基于唯一 nonce 的 CBC

如果应用只能提供唯一但可预测的 nonce，不能直接把它当作随机 CBC IV。

课程给出的构造使用独立密钥 k_1 将 nonce 变成伪随机 IV：

$$IV = E(k_1, n)$$

然后使用另一个密钥 k 执行 CBC：

$$c[i] = E(k, m[i] \oplus c[i - 1])$$

其中 $c[-1] = IV$ 。

15.1 为什么需要独立密钥

概念上, k_1 负责 nonce 到 IV 的伪随机化, k 负责消息分组加密。分离用途便于安全证明, 并避免同一原语输入域之间产生不必要关联。

15.2 nonce 的要求

(k, n) 在同一密钥生命周期内只使用一次

nonce 可以公开, 也可以是计数器。

如果解密端不能从状态推导 nonce, 就需要将 nonce 随密文发送; 不必额外发送可由 nonce 计算出的 IV。

16. CBC 填充

16.1 为什么需要填充

CBC 每次只能处理一个完整分组。如果消息长度不是分组长度的整数倍, 就要补齐最后一块。

对于 AES:

block size = 16 字节

16.2 常见长度填充

若需要补 n 个字节, 则附加 n 个值为 n 的字节:

... | n n ... n
共 n 个

例如还差 5 字节:

05 05 05 05 05

解密端读取末字节, 检查并删除相应数量的填充。

16.3 恰好整块时为什么还要添加一块

若明文已经是完整分组, 仍需添加一整个填充分组。否则解密方无法判断最后几个自然明文字节究竟是数据还是填充。

对于 16 字节分组, 整块填充通常表现为:

10 10 10 ... 10

不同协议的具体填充值定义可能略有区别，应严格遵循所用标准。

16.4 填充不提供安全认证

填充只是长度编码。若系统根据“填充是否合法”向攻击者暴露不同错误，就可能产生 padding oracle。

本讲尚未展开完整性，但必须记住：CBC 加密应与安全认证组合，不能把填充检查当作完整性保护。

17. CTR：随机计数器模式

17.1 构造

设：

$$F : \mathcal{K} \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

是安全 PRF。随机选择：

$$IV \leftarrow \{0, 1\}^n$$

生成密钥流：

$$F(k, IV), F(k, IV + 1), \dots, F(k, IV + L)$$

加密：

$$c[i] = m[i] \oplus F(k, IV + i)$$

完整密文：

$$c = IV \parallel c[0] \parallel \dots \parallel c[L]$$

解密使用同样运算：

$$m[i] = c[i] \oplus F(k, IV + i)$$

17.2 CTR 把分组密码变成流密码

CTR 不直接用分组密码加密明文，而是用分组密码/PRF 生成密钥流，再与明文异或：

```
counter inputs -> F(k,.) -> keystream
message XOR keystream -> ciphertext
```

因此，AES-CTR 中只需要 AES 的加密方向，不需要 AES 解密算法。

17.3 并行处理

各分组所需输入：

$$IV, IV + 1, \dots, IV + L$$

可以提前计算且互不依赖，所以加密和解密都能并行。

17.4 随机访问

要解密第 i 个分组，只需：

$$m[i] = c[i] \oplus F(k, IV + i)$$

不必先解密前面的分组，因此 CTR 很适合支持随机访问。

17.5 不需要填充

CTR 产生的是密钥流。最后不足一个完整分组时，只取密钥流所需的前若干字节即可，因此无需填充，也不会额外添加完整填充分组。

18. 基于 nonce 的 CTR

18.1 nonce 与块计数器拼接

对于 128 位 AES 输入，可以划分为：

高 64 位：消息 nonce
低 64 位：消息内 block counter

例如：

$$IV_i = n \parallel i$$

其中每条新消息使用不同 n ，每条消息内部的 i 从 0 开始递增。

18.2 真正不能重复的是什么

关键要求不是“完整 IV 看起来随机”，而是同一密钥下所有 PRF 输入都必须唯一：

$$(n, i) \neq (n', i')$$

否则：

$$F(k, n \parallel i)$$

会重复，造成密钥流复用。

18.3 counter 回绕

若低位 counter 达到最大值后回绕到 0，也会复用 PRF 输入。因此实现必须限制单条消息的最大分组数。

18.4 nonce 重用后果

若两条消息使用相同 nonce 且 counter 都从 0 开始：

$$c_1[i] = m_1[i] \oplus F(k, n \parallel i)$$

$$c_2[i] = m_2[i] \oplus F(k, n \parallel i)$$

则：

$$c_1[i] \oplus c_2[i] = m_1[i] \oplus m_2[i]$$

这与重复使用流密码密钥完全相同。

19. CTR 的 CPA 安全界

对于随机 IV CTR，若 F 是安全 PRF，课程给出：

$$\text{Adv}_{\text{CPA}}[A, E_{\text{CTR}}] \leq 2 \text{Adv}_{\text{PRF}}[B, F] + \frac{2q^2 L}{|\mathcal{X}|}$$

因此需要：

$$q^2 L \ll |\mathcal{X}|$$

19.1 为什么是 (L) 而不是 (L^2)

每条 CTR 消息占据一段连续计数器区间：

$$[IV, IV + L]$$

两条消息发生密钥流重叠，只需它们的起始 IV 距离不超过约 L 。对两条消息，危险起始值约有 $O(L)$ 个，而不是任意两个内部状态自由碰撞的 $O(L^2)$ 个。

因此总体碰撞项约为：

$$\frac{q^2 L}{|\mathcal{X}|}$$

这比随机 IV CBC 的：

$$\frac{q^2 L^2}{|\mathcal{X}|}$$

更好。

19.2 AES 示例

若：

$$|\mathcal{X}| = 2^{128}$$

并希望碰撞项低于约 2^{-32} ，需要近似满足：

$$q\sqrt{L} < 2^{48}$$

PPT 示例取：

$$q = 2^{32}, \quad L = 2^{32}$$

则总共可处理：

$$qL = 2^{64}$$

个 AES 分组后再更换密钥。

这些是用于理解具体安全界的估算，实际系统还必须遵守所用标准给出的更严格消息数和数据量限制。

20. CBC 与 CTR 对比

对比项	CBC	CTR
使用的抽象	PRP	PRF
基本操作	明文与前一密文异或后加密	PRF 生成密钥流后与明文异或
加密并行	不可以	可以
解密并行	可以	可以
随机访问	不方便	方便
是否需要填充	需要	不需要
密文长度	IV + 整数个完整分组	IV/nonce + 原消息长度
随机 IV 安全条件	$q \cdot 2L^2 \ll 2^n$	$\mathcal{X}$
IV/nonce 重用	泄露首块关系并破坏安全	直接复用密钥流，后果严重
是否提供完整性	否	否

20.1 短消息扩张

对于 AES-CBC，一条 1 字节消息仍需要：

- 一个 16 字节密文分组；
- 可能还要发送一个 16 字节 IV/nonce 相关值。

课程表格强调 CBC 的填充分组会造成显著扩张。CTR 不需要把消息补成整块，所以正文部分无这种扩张。

CBC 可使用 ciphertext stealing 等专门技术减少某些填充扩张，但这属于额外模式设计，不能自行临时发明。

21. CBC 与 CTR 都不提供完整性

本课的所有安全定义关注的是窃听攻击下的保密性，而不是主动篡改。

21.1 CTR 的可篡改性

CTR 密文：

$$c = m \oplus s$$

攻击者改为：

$$c' = c \oplus \Delta$$

解密结果：

$$m' = m \oplus \Delta$$

攻击者可以精确翻转指定明文位。

21.2 CBC 的可篡改性

CBC 解密：

$$m[i] = D(k, c[i]) \oplus c[i - 1]$$

若攻击者修改 $c[i - 1]$ ：

- 会对 $m[i]$ 产生可预测的位翻转；
- 同时会使前一个分组的解密结果发生不可预测变化。

因此 CBC 也具有可篡改性。

21.3 正确工程方案

现代系统应优先使用认证加密 AEAD，例如：

- AES-GCM；
- ChaCha20-Poly1305。

它们同时提供：

- 保密性；
- 完整性；
- 消息认证；
- 对附加但不加密数据的认证。

22. IV、nonce 与 counter 对照

名称	是否需要随机	是否需要唯一	是否需要不可预测	是否需要保密
CBC 随机 IV	是	高概率唯一	是	否
CBC nonce	nonce 本身不必随机	是	nonce 不必；但需先经 PRP 变成伪随机 IV	否
CTR 随机 IV	是	相关计数区间高概率不重叠	通常由随机选择保证	否
CTR nonce	不必随机	是	否	否
消息内 counter	不必随机	在该 nonce 下不能重复	否	否

最容易混淆的是：

CBC 的随机 IV 不仅要不重复，还要在当前明文确定前不可预测；CTR 的 nonce 通常只要求唯一。

不同标准可能对 IV/nonce 布局提出更具体要求，应以算法规范为准。

23. 常见误区

误区 1: AES 本身可以直接加密任意长消息

错误。AES 只定义 128 位分组上的置换，还需要安全工作模式。

误区 2: ECB 使用强 AES，所以 ECB 也安全

错误。ECB 会泄露重复分组和数据结构；强原语不能挽救错误的组合方式。

误区 3: 同一密钥下重复加密同一明文，得到相同密文没有关系

错误。这会直接泄露消息相等关系，并可在小消息空间中支持字典攻击。

误区 4: nonce 必须随机且保密

错误。nonce 的基本要求通常是同一密钥下唯一，可以公开，也可以是计数器。

误区 5: CBC 的 IV 只要唯一即可

错误。随机 IV CBC 要求 IV 在选择当前明文时不可预测。可预测的唯一 IV 仍可能破坏 CPA 安全。

误区 6: 随机选择 IV 就绝对不会重复

错误。随机值只是在足够大空间中以高概率不重复，碰撞概率受生日界控制。

误区 7: CTR 的 counter 可以在每条消息都从 0 开始

只有每条消息的 nonce 不同时才可以。真正的 PRF 输入是 (nonce, counter)，整个组合不能重复。

误区 8: CTR 使用 AES，所以需要 AES 解密函数

错误。加密和解密都只计算 AES/PRF 的正向输出，再执行异或。

误区 9: CBC 解密不能并行

错误。CBC 加密有链式依赖；解密时所有密文块已知，分组密码逆运算可以并行。

误区 10: CBC 或 CTR 已经防止密文篡改

错误。两者只讨论保密性，均不提供完整性，应使用 AEAD。

误区 11: 填充合法就说明密文可信

错误。填充只是编码规则，不能代替认证；泄露填充错误还可能造成 padding oracle。

误区 12: 安全界中的限制只与密钥长度有关

错误。CBC/CTR 的数据量限制还受到分组空间 $|\mathcal{X}|$ 、消息数 q 和最大消息长度 L 影响。

24. 必会公式

24.1 PRF Switching Lemma

$$|\text{Adv}_{\text{PRF}} - \text{Adv}_{\text{PRP}}| < \frac{q^2}{2|\mathcal{X}|}$$

24.2 确定性 CTR

$$c[i] = m[i] \oplus F(k, i)$$

24.3 随机化 PRF 加密

$$c = (r, F(k, r) \oplus m)$$

24.4 CBC 加密

$$c[-1] = IV$$

$$c[i] = E(k, m[i] \oplus c[i-1])$$

24.5 CBC 解密

$$m[i] = D(k, c[i]) \oplus c[i-1]$$

24.6 CBC 安全条件

$$q^2 L^2 \ll |\mathcal{X}|$$

24.7 CTR 加密与解密

$$c[i] = m[i] \oplus F(k, IV + i)$$

$$m[i] = c[i] \oplus F(k, IV + i)$$

24.8 CTR 安全条件

$$q^2 L \ll |\mathcal{X}|$$

24.9 nonce CTR 输入

$$x_i = n \parallel i$$

24.10 密钥流复用

$$c_1[i] \oplus c_2[i] = m_1[i] \oplus m_2[i]$$

25. 自测题

题 1

为什么一个安全 PRP 在很小的定义域上不一定是安全 PRF?

题 2

PRF Switching Lemma 中的 $q^2/|\mathcal{X}|$ 与生日攻击有什么关系?

题 3

为什么 ECB 即使使用 AES 并且每条消息使用新密钥, 也不能安全加密含多个分组的消息?

题 4

单次密钥语义安全与多次密钥 CPA 安全的攻击者能力有何区别?

题 5

为什么确定性计数器模式只能在密钥使用一次时安全?

题 6

在 CPA 游戏中, 攻击者如何利用确定性加密区分 m_0 和 m_1 ?

题 7

随机化方案

$$(r, F(k, r) \oplus m)$$

除了要求 F 安全, 还必须满足什么条件?

题 8

nonce 是否必须保密? “同一 nonce 只能使用一次”的完整表述是什么?

题 9

写出 CBC 的加密和解密公式。

题 10

为什么 CBC 的可预测 IV 会破坏 CPA 安全?

题 11

如果只有唯一计数器 nonce, 如何为 CBC 产生安全 IV?

题 12

为什么 CBC 在明文恰好为完整分组时仍需添加填充分组?

题 13

CTR 为什么可以并行并且无需填充?

题 14

在 nonce CTR 中, nonce 可以为每条消息固定从 0 开始吗? counter 可以吗?

题 15

为什么随机 IV CTR 的安全界中是 q^2L , 而随机 IV CBC 中是 q^2L^2 ?

题 16

CBC 和 CTR 是否提供密文完整性? 攻击者篡改 CTR 密文会发生什么?

26. 自测题参考答案

答 1

PRP 不允许不同输入产生相同输出, 而随机函数允许碰撞。在很小定义域上, 攻击者用少量查询就能观察碰撞差异。定义域足够大且查询量远低于生日界时, 这种差异才可忽略。

答 2

随机函数在 q 个输出中发生碰撞的概率约为 $q^2/(2|\mathcal{X}|)$ 。随机置换不碰撞, 因此该概率就是区分随机函数和随机置换的主要额外优势。

答 3

ECB 对每个分组确定性加密。相同明文分组必然产生相同密文分组, 攻击者可利用相等模式区分消息内容。

答 4

单次密钥模型中攻击者只看到一个由新密钥产生的挑战密文; CPA 模型中同一密钥被多次使用, 攻击者能自适应请求许多自选消息的加密结果。

答 5

同一密钥再次从计数器 0 开始会重复 $F(k, 0), F(k, 1), \dots$, 形成 two-time pad, 两个密文异或会消去密钥流。

答 6

攻击者先请求 m_0 的加密得到 c_0 , 再提交挑战对 (m_0, m_1) 。若挑战密文等于 c_0 就判断加密的是 m_0 , 否则判断是 m_1 。

答 7

随机数空间必须足够大, 使同一密钥下 r 的重复概率可忽略。若 r 重复, PRF 输出和密钥流也会重复。

答 8

nonce 通常公开, 不必保密。完整要求是同一密钥下 (key, nonce) 组合不能重复, 而不是 nonce 在所有用户 and 所有密钥中全局唯一。

答 9

令 $c[-1] = IV$:

$$c[i] = E(k, m[i] \oplus c[i-1])$$

$$m[i] = D(k, c[i]) \oplus c[i-1]$$

答 10

攻击者知道下一 IV 后, 可以调整挑战明文, 使 明文 XOR 新 IV 等于之前出现过的分组密码输入。通过比较输出密文是否相等即可区分挑战消息。

答 11

用独立密钥通过 PRP 计算:

$$IV = E(k_1, n)$$

再用另一个密钥 k 执行 CBC。nonce 必须唯一。

答 12

否则解密方无法区分末尾自然出现的字节和填充长度。始终添加填充可以让解码规则无歧义。

答 13

每块密钥流 $F(k, IV + i)$ 可独立计算, 因此可以并行。最后一个不完整分组只需使用密钥流的对应字节, 所以无需补齐。

答 14

每条消息内部 counter 可以从 0 开始, 但每条消息的 nonce 必须不同。真正输入是 (nonce, counter), 同一密钥下这个完整组合不能重复。

答 15

CTR 中两条消息发生危险的条件是两个长度约 L 的计数区间重叠, 对每对起始 IV 约有 $O(L)$ 个危险偏移。CBC 中约 qL 个内部输入可以任意两两碰撞, 得到 $(qL)^2 = q^2 L^2$ 项。

答 16

都不提供完整性。CTR 中攻击者把密文异或 Δ , 解密后的明文也会在相同位置异或 Δ , 实现可预测位翻转。

27. 一页式总结

分组密码只是原语

AES: $K \times \{0,1\}^{128} \rightarrow \{0,1\}^{128}$

必须通过安全模式处理长消息

ECB

$$c[i] = E(k, m[i])$$

相同明文块 -> 相同密文块

不具备语义安全性

单次密钥

确定性 CTR 可以安全: $c[i] = m[i] \text{ XOR } F(k, i)$

但密钥不能再次使用

多次密钥 CPA

攻击者可以请求许多自选消息的加密

同一明文的重复加密必须产生不同密文

随机化加密

$$c = (r, F(k, r) \text{ XOR } m)$$

r 必须在足够大空间中随机选择, 碰撞概率可忽略

nonce 加密

nonce 不必随机或保密

同一密钥下 nonce 必须唯一

CBC

$$c[i] = E(k, m[i] \text{ XOR } c[i-1])$$

$$m[i] = D(k, c[i]) \text{ XOR } c[i-1]$$

随机 IV 必须不可预测

需要填充, 加密不能并行

安全条件: $q^2 L^2 \ll |X|$

CTR

$$c[i] = m[i] \text{ XOR } F(k, IV+i)$$

可并行、可随机访问、无需填充

所有 counter 输入不能重复

安全条件: $q^2 L \ll |X|$

重要局限

CBC 与 CTR 只提供保密性, 不提供完整性

现代实践优先使用 AES-GCM 或 ChaCha20-Poly1305

28. 学习建议

第一遍: 先区分 PRP、PRF、单次密钥和多次密钥四个概念。

第二遍: 不看笔记写出 ECB 攻击、确定性加密 CPA 攻击和可预测 CBC IV 攻击。

第三遍: 独立推导 CBC 加解密公式, 并画出 CBC 和 CTR 的数据流。

第四遍: 重点比较随机 IV 与唯一 nonce 的不同要求。

最后完成第 25 节自测题, 尤其检查第 5、10、14、15、16 题。

范围说明: 本讲只建立窃听/CPA 模型下的保密性。消息认证、认证加密、padding oracle 的完整分析以及主动攻击安全将在后续课程继续讨论。